

Postal Address:

Box 8114

104 20 Stockholm

Website:

www.imy.se

Email:

imy@imy.se

Phone:

08-657 61 00

1(9)

Hospital Board of Region Uppsala

Decision following supervision under the

Data Protection Regulation –

Hospital Board of Region Uppsala

Decision of the Swedish Authority for Privacy Protection

The Swedish Authority for Privacy Protection (IMY) finds that the Hospital Board of Region Uppsala, from May 25, 2018, to November 29, 2022, in its capacity as data controller, has processed personal data in violation of Article 32.1 of the Data Protection Regulation by failing to implement appropriate technical and organizational measures to ensure a security level that is appropriate in relation to the risks associated with the processing of patients' personal data in the organization's email service.

IMY issues a reprimand to the Hospital Board of Region Uppsala based on Article 58.2 b of the Data Protection Regulation for the identified violation.

Account of the supervisory matter

Background

The Hospital Board of Region Uppsala (hereinafter referred to as the Hospital Board) provides and performs healthcare under the Health and Medical Services Act (2017:30), HSL, at Uppsala Academic Hospital and the Hospital in Enköping. On November 29, 2022, IMY received a report of a personal data incident that occurred within the framework of the Hospital Board's healthcare activities. The report concerned the discovery that personal data about patients, including personal identification numbers and health information, had been processed in the email service Microsoft Outlook during the period 2014–2022. According to the report, the incident was due to a lack of organizational routines or processes.

In light of the report, IMY initiated supervision of the Hospital Board to verify whether the Hospital Board, in its capacity as a healthcare provider under HSL, had taken appropriate measures to ensure the protection of patients' personal data when processing their personal data in the email service Microsoft Outlook. As part of the supervision, an on-site inspection was conducted on March 8, 2023, at the Hospital Board's premises.

IMY's review includes the question of whether the Hospital Board meets the security requirements set out in Article 32 of the Data Protection Regulation regarding the processing of personal data in the email service. The examination in the matter has been limited to the question of whether the Hospital Board has taken sufficient organizational and technical measures to prevent and detect unauthorized processing of personal data in the email service.

The review does not cover whether the processing is compliant with the regulations of the Data Protection Regulation in other respects.

The Data Protection Regulation began to apply on May 25, 2018. Therefore, IMY's supervision covers the period from May 25, 2018, to November 29, 2022, when the report of the personal data incident was received.

Previous decisions

On January 26, 2022, IMY issued an administrative fine against the Hospital Board after finding that the Hospital Board had processed personal data in violation of Articles 5.1 f and 32.1 of the Data Protection Regulation by sending unencrypted sensitive personal data to patients and referrers in third

countries and storing sensitive personal data in the email service (DI-2021-5595). The supervision was initiated following a personal data incident reported to IMY in 2019. IMY assessed that the Hospital Board had not taken appropriate technical and organizational measures to ensure a security level that was adequate in relation to the risks associated with the processing.

Account from the Hospital Board

Within the framework of the supervision, the Hospital Board has stated the following.

Data Controller

The Hospital Board provides and performs healthcare under HSL at Uppsala Academic Hospital and the Hospital in Enköping. The Hospital Board is the data controller according to Chapter 2, Section 6 of the Patient Data Act (2008:355), PDL. It is thus the data controller when processing personal data about patients for the purposes outlined in Chapter 2, Section 4 of the PDL, such as documenting information in patient records.

General information about the email service

In the operations at Uppsala Academic Hospital and the Hospital in Enköping, the email service Microsoft Outlook has been used since 2014. Microsoft provides the operation of the email service in its data centers and supports Region Uppsala's administrative object Digital Workplace, which in turn administers the service within the region.

The relevant email service has approximately 8,300 users within the Hospital Board's operations, of which the majority (about 6,400) work in healthcare.

Personal data incident

When processing a request for a register extract on November 24, 2022, it was discovered that personal data about patients had been sent in an email between employees within the framework of the Hospital Board's healthcare activities. The email stored in the email service contained Excel files with information about patients, including names, personal identification numbers, number of hospital visits, and number of days of care.

Following this discovery, the Hospital Board initiated an investigation and found additional unencrypted emails that had been sent during the period 2010–2022 containing personal data about patients.

During the investigation, 15 emails containing personal data about patients were discovered, as well as a recurring automated dispatch for merging personal identification numbers.

Integrity Protection Authority

Diary Number: IMY-2023-2522

3(9)

Date: 2025-04-24

There have been emails exchanged between staff at the hospitals, and no indications have emerged of email conversations directly between healthcare personnel and patients.

Technical and Organizational Measures

There are governing document management plans for Uppsala Academic Hospital and the Hospital in Enköping, which specify which documents and information volumes are managed, in which systems they should be stored, and how long the information should be retained. There is also an archive handbook that generally describes rules and procedures for deletion, including the deletion of emails, as well as a retention and deletion plan for administrative documents that specifies rules regarding the deletion of emails.

When an email is received, the starting point is that it should be handled and registered in the system where the documents belong. Thereafter, the documents should be deleted from the email service.

Correspondence of temporary and minor significance may be deleted when it becomes outdated.

At the regional level, there are guidelines and decisions stating that sensitive information should not be handled via email. Uppsala Academic Hospital and the Hospital in Enköping each have regulations for handling emails that specify that sensitive information, such as confidential information and sensitive personal data, must not be included in emails unless the files are encrypted. By default, emails are encrypted with TLS during transport. However, it cannot be guaranteed that all emails are encrypted with TLS during transport as this setting depends on the recipient/sender. If email is used to send

sensitive information, it must be encrypted with the encryption solutions that Region Uppsala has approved for sending such information.

It is also stated in a regional director's decision from 2019 and in the guideline "Information Security for Employees" that if email is to be used for sensitive information, the information must be encrypted.

Other communication channels where the importance of secure email is emphasized include, for example, management letters and mandatory training sessions.

Despite the measures taken, there may be individual employees who, out of ignorance or by mistake, email sensitive personal data unencrypted. The maturity level regarding the secure handling of sensitive information is perceived by the Hospital Board as high. However, since healthcare personnel do not primarily work in the email service, there is a risk that routines for the correct handling of sensitive information become less known.

The email content of individual employees is not monitored. Employees work based on a trust that is granted upon employment to follow the internal regulations regarding storage and deletion. Only the individual employee has access to their email and can delete their emails that contain sensitive information.

When an employee leaves, the email account is terminated, and all emails are removed, but there is no permanent technical functionality for automatically deleting emails. However, work is ongoing to review the conditions for deleting emails older than 2014.

Actions After the Incident

When the incident was discovered, it was reported to the Data Protection Officer, and meetings were convened to quickly investigate the extent of the incident and to assess what type of information had been found. A group was formed with the responsibility to manage the incident and to identify and implement the immediate actions required. In the

Swedish Authority for Privacy Protection

Case Number: IMY-2023-2522

4(9)

Date: 2025-04-24

In the acute situation following the discovery and reporting of the incident, the identified emails were deleted. The emails that had previously been automatically generated were also removed. Information was sent out to employees to clarify how sensitive personal data should be handled correctly.

The hospital board completed a risk and vulnerability analysis in the spring of 2022 – that is, after IMY's previous decision (DI-2021-5595). This resulted in a list of measures (the activity list) to address a number of identified risks related to, among other things, email management. In connection with the current incident, reprioritizations were made in the ongoing work with the activity list. Work continues on the measures that have been identified.

Examples of measures that have been implemented include investigating possibilities for deleting subsets in the email service and introducing features in the email service that can inform and warn users attempting to send emails containing personal identification numbers. The ability to send secure messages between users has been launched, and work is also ongoing to connect Region Uppsala to the national service Secure Digital Communication provided by the Agency for Digital Administration (DIGG).

Regarding the automatic mailings, they will cease in the form that existed at the time of the incident.

Justification of the decision

Applicable regulations

The responsibility of the data controller

The entity that alone or jointly with others determines the purposes and means of processing personal data is the data controller. If the purposes and means of processing are determined by Union law or the national law of the Member States, the data controller or the specific criteria for how they are to be designated may be prescribed in Union law or in the national law of the Member States. This is stated in Article 4.7 of the General Data Protection Regulation.

According to Chapter 2, Section 6, first paragraph of the PDL, a healthcare provider is the data

controller for the processing of personal data that the healthcare provider performs. In a region and a municipality, each authority that conducts health and medical care is the data controller for the processing of personal data that the authority performs.

The data controller has a responsibility to implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing of personal data is carried out in accordance with the General Data Protection Regulation. This is evident from the fundamental principles in Article 5, but is also regulated in Article 24 of the Regulation.

The measures must be implemented taking into account the nature, scope, context, and purposes of the processing as well as the risks, of varying likelihood and severity, to the rights and freedoms of natural persons. The measures must be reviewed and updated as necessary.

1 <https://www.digg.se/saker-digital-kommunikation>

Swedish Authority for Privacy Protection

Diary Number: IMY-2023-2522

5(9)

Date: 2025-04-24

Requirement for Security in the Processing of Personal Data, etc.

Health information constitutes so-called sensitive personal data. It is prohibited to process such personal data according to Article 9.1 of the General Data Protection Regulation (GDPR), unless the processing falls under one of the exceptions in Article 9.2 of the regulation.

According to Article 32.1 of the GDPR, the data controller shall implement appropriate technical and organizational measures to ensure a level of security that is appropriate in relation to the risk associated with the processing of personal data. This shall be done taking into account the latest developments, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks, varying in likelihood and severity, to the rights and freedoms of natural persons. This includes, where appropriate, the ability to continuously ensure the confidentiality, integrity, availability, and resilience of processing systems and services, as well as a procedure for regularly testing, assessing, and evaluating the effectiveness of the technical and organizational measures that are to ensure the security of the processing.

In assessing the appropriate level of security, special consideration shall be given to the risks posed by the processing, particularly from accidental or unlawful destruction, loss, or alteration, or from unauthorized disclosure of or unauthorized access to the personal data that has been transmitted, stored, or otherwise processed. This is stated in Article 32.2 of the GDPR.

Recital 75 of the GDPR specifies the factors to be considered in assessing the risk to the rights and freedoms of natural persons that may arise from the processing of personal data. Among other things, consideration should be given to whether the processing concerns personal data about health or vulnerable natural persons, especially children, or whether the processing involves a large amount of personal data and concerns a large number of data subjects.

IMY's Assessment

Data Controller

The Hospital Board has stated that it provides and performs care at Uppsala Academic Hospital and the Hospital in Enköping and is the data controller according to Chapter 2, Section 6 of the PDL (Swedish Data Protection Act). Thus, the Hospital Board is the data controller for the personal data processing that the Hospital Board performs within the framework of its care activities, which according to IMY includes the processing of personal data about patients within the Hospital Board's operations when such data is processed in the email service. The Hospital Board is therefore the data controller for the processing of personal data in the email service relevant to this case.

Technical and Organizational Measures

The processing has involved a high risk and required a high level of protection

The Hospital Board conducts healthcare activities, which means that sensitive and particularly protected personal data is processed within the operations to a large extent. IMY can also note that the majority of the Hospital Board's users of the email service consist of approximately 6,400 individuals

working in healthcare. This presents a significant risk that personal data, including sensitive and particularly protected data, may be handled in the email service. This is supported by the fact that the Hospital Board has stated that

Swedish Authority for Privacy Protection

Diary Number: IMY-2023-2522

6(9)

Date: 2025-04-24

there is a risk that a user may inadvertently send sensitive personal data via the email service.

The overarching purpose of an email service is to receive, disseminate, and communicate information. IMY has previously assessed in its supervision of the Hospital Board (DI-2021-5595) that email systems are generally an unsuitable storage location for sensitive personal data. An email system is exposed to the internet, which means that the data in the system risks becoming accessible to unauthorized persons. The fact that it is primarily the individual users who are aware of which data the users handle in the email service can further lead to difficulties for the data controller in ensuring that data is not handled in the service in an unauthorized manner. Processing of personal data in an email service thus entails specific risks.

Against this background, IMY believes that high demands must be placed on the technical and organizational measures that the Hospital Board needs to implement to ensure an appropriate level of security regarding the processing of personal data in the email service.

The Hospital Board has not implemented sufficient security measures

As stated in Article 32.2 of the General Data Protection Regulation, particular consideration must be given to the risks posed by processing when assessing the appropriate level of security, especially from accidental or unlawful destruction, loss, or alteration, or from unauthorized disclosure of or unauthorized access to the personal data being processed. The data controller must therefore take measures to avoid personal data incidents as much as possible.

The measures may include, among other things, the ability to continuously ensure confidentiality, integrity, availability, and resilience of the processing systems and services, as well as a procedure for regularly testing, examining, and evaluating the effectiveness of the technical and organizational measures that are to ensure the security of the processing.

In this context, it is important that the data controller takes measures to prevent and detect unauthorized processing of personal data.

The investigation in the matter shows that during the relevant time period, there were central documents and rules applicable within the Hospital Board's operations that, among other things, focus on the handling of documents and information volumes as well as the handling of personal data in email. These documents state, among other things, that privacy-sensitive data such as personal identification numbers, confidential information, and sensitive personal data must not occur in emails unless the files are encrypted with an approved encryption solution. Employees are also required to undergo mandatory training, including regarding information security and handling of personal data in the email service.

The Hospital Board had therefore implemented a number of measures to prevent unauthorized processing of personal data in the email service. However, in light of the fact that during the personal data incident in question, it was revealed that sensitive and particularly protected personal data had been processed in the email service, it is evident that employees did not follow the guidelines that existed regarding the processing of such personal data in the email service. It can also be noted that there were established

2 Court of Justice of the European Union judgment of December 14, 2023, Natsionalna agentsia za prihodite, case C-340/21, ECLI:EU:C:2023:986, paragraph 30.

Swedish Authority for Privacy Protection

Case Number: IMY-2023-2522

7(9)

Date: 2025-04-24

services for automatic dispatches that continuously sent personal data about patients via email in violation of the guidelines.

The measures taken to prevent unauthorized processing of personal data in the email service have, according to IMY, primarily consisted of organizational security measures, such as rules, guidelines, and training on how staff working within the organization should handle sensitive data. The hospital board has indeed taken a number of technical measures after the incident to prevent unauthorized processing, for example regarding functions to inform and warn users attempting to send emails containing personal identification numbers. However, such functions were not in place at the time of the incident.

Several of the emails involved in the incident had been stored in the email service for a long time, indicating that the hospital board did not have an effective procedure to follow up and evaluate the effectiveness of the measures taken. The fact that the discovery of a large amount of sensitive and particularly protected personal data that had been processed for an extended period in the email service occurred during the handling of a request for a register extract also indicates a lack of proactive measures to detect unauthorized processing. IMY further notes that at the time of the personal data incident, it was up to individual employees to detect and delete emails containing sensitive or particularly protected personal data.

Overall, IMY assesses that the hospital board has not taken sufficient measures to prevent and detect unauthorized processing of personal data in the email service.

Thus, from May 25, 2018, to November 29, 2022, the hospital board, as the data controller, processed personal data in violation of Article 32.1 by failing to implement appropriate technical and organizational measures to ensure a security level that is adequate in relation to the risks associated with the processing of patients' personal data in the email service.

Choice of Intervention

Article 58.2 and Article 83.2 of the General Data Protection Regulation indicate that IMY has the authority to impose an administrative fine. Depending on the circumstances of the individual case, an administrative fine shall be imposed in addition to or instead of the other measures referred to in Article 58.2, such as orders and prohibitions. Furthermore, Article 83.2 specifies the factors to be considered when deciding whether to impose an administrative fine and when determining the amount of the fine. Consideration should be given to aggravating and mitigating circumstances in the case, such as the nature, severity, and duration of the infringement, as well as previous relevant infringements. If it concerns a minor infringement, IMY may, as indicated in Recital 148, instead of imposing a fine, issue a reprimand in accordance with Article 58.2 b.

IMY has assessed above that the hospital board has processed personal data in violation of Article 32.1 of the General Data Protection Regulation. An infringement of that provision may lead to an administrative fine.

During the relevant period in this case, the hospital board did not take sufficient technical and organizational measures to prevent and detect unauthorized processing of personal data in the email service. The inadequate measures have led to a large amount of sensitive and particularly protected personal data being processed in

Swedish Authority for Privacy Protection

Case Number: IMY-2023-2522

8(9)

Date: 2025-04-24

the email service in violation of the hospital board's guidelines. The hospital board has previously been ordered by IMY to pay an administrative fine for, among other things, a violation of Article 32.1 in the handling of personal data in the email service (DI-2021-5595). Following IMY's previous decision, the hospital board completed a risk and vulnerability analysis that resulted in an action list to address identified risks related to, among other things, email usage. In connection with the personal data incident relevant to this case, reprioritizations were made in the ongoing work with the action list. The action list shows both completed and planned technical and organizational measures aimed at

increasing the ability to prevent and detect unauthorized processing of personal data.

The hospital board has also decided to cease the automatic dispatches with personal number merges in the form that was relevant at the time of the incident.

Upon a comprehensive assessment of the circumstances in the case, IMY considers that it is not proportionate to decide on a fine for the infringement identified in this supervision. Therefore, the hospital board shall, instead of a fine, receive a reprimand in accordance with Article 58.1 b of the General Data Protection Regulation.

This decision has been made by the unit manager Christelle Bourquin after presentation by the IT and information security specialist Johnny Gordon Tornesjö. The department lawyer Andreas Persson has also participated in the final processing of the case.

Christelle Bourquin

Copy to

Data Protection Officer

Swedish Authority for Privacy Protection

Case Number: IMY-2023-2522

9(9)

Date: 2025-04-24

How to Appeal

If you wish to appeal the decision, you must write to IMY. In your letter, specify which decision you are appealing and the change you are requesting. The appeal must be received by IMY within three weeks from the day you were notified of the decision. However, if you are a party representing the public interest, the appeal must be received within three weeks from the day the decision was announced. If the appeal is submitted in a timely manner, IMY will forward it to the Administrative Court in Stockholm for examination.

You may email the appeal to IMY if it does not contain any sensitive personal data or information that may be subject to confidentiality. The authority's contact details are provided on the first page of the decision.